A21 — Preparação docente: o que dominar e caminho de estudo

Documento docente, fora do site. Reúne o conteúdo a dominar, o caminho de estudo, a condução do encontro e as respostas dos checkpoints. Versão de 12 nov. 2026, alinhada à página publicada no commit `444ae0ec`.

O que dominar

1. Pentest × outras atividades

- O pentest tenta **usar** a falha para provar, com evidência, que uma premissa de segurança é falsa.
- Varredura lista condições conhecidas. Auditoria compara configuração e regra. Red team testa detecção e resposta.
- Frase-chave: **alerta não é achado**. Alerta → hipótese → teste → evidência → achado.

2. ROE: o que torna o teste legal

- Quem responde pelo sistema concede a autorização; quem testa assina que vai cumpri-la. Sem isso, é invasão (CP, art. 154-A).
- Ligar cada item a uma pergunta da abertura:

Pergunta	Item do ROE
O que será testado?	Alvo e fora do escopo
Quando e com quem?	Janela e contas
Até onde?	Técnicas e intensidade
Como parar?	Critério de parada e recuperação
O que conta como prova?	Evidência e seu tratamento

- Valores do trabalho (roteiro v1.2, seção 3):
  - ZAP ≤ 10 req/s; `ffuf` ≤ 20 req/s; Fuzzer com 2 threads e 100 ms;
  - varredura ativa só na P9, até 30 min;
  - parar com alvo sem resposta por mais de 2 min.

3. Ciclo da SP 800-115

- Quatro fases: planejamento → descoberta → ataque → relatório.
- "Ataque" = **validar com a menor ação suficiente**. Ler um dado de outra conta prova a falha; apagar não prova nada a mais e viola o ROE.
- Descoberta e validação formam um laço: uma hipótese descartada leva de volta à descoberta.
- P10–P13 ficam sob "Relatório" por aproximação. Cada uma tem análise e validação próprias (correção → reteste → regressão).

4. Referenciais pela função

- Metodologia organiza (SP 800-115, PTES). Guia de testes testa (WSTG). Padrão de requisitos define o esperado (ASVS). Taxonomia classifica (CWE). Métrica pontua (CVSS).
- **CVE** = falha concreta em produto e versão. **CWE** = tipo de defeito. **ATT&CK** = ação do atacante. Muitas CVEs têm a mesma CWE.
- **OSSTMM** mede a exposição (porosidade: visibilidade, acesso, confiança). Só o conceito entra no trabalho.

- **CVSS 4.0**: nota de 0 a 10 a partir de um vetor; o trabalho exige CVSS-B. O Risk Rating acrescenta o contexto do negócio.
- Erro a desfazer: o Top 10 é lista de conscientização, não classificação. Classificação = CWE + WSTG.
- Não é preciso dominar OSSTMM e PTES a fundo, só saber para que servem.

5. ZAP: onde a turma tropeça

- **Contexto:** o ZAP compara a URL **inteira** com a expressão. O perigo real é o `.` sem escape (casa qualquer caractere) e o `.*` colado na porta (aceita `:30001`). `^` e `$` importam em ferramentas que procuram trecho.
- **Protected:** impede o ZAP de **atacar** fora do contexto; não impede o navegador de **carregar** outros endereços.
- **Threads × taxa:** threads limitam concorrência. Com respostas rápidas, duas threads geram dezenas de req/s; quem impõe o teto é o Rate Limit e o atraso do Fuzzer.
- **Rate Limit** vale para o que sai do ZAP; o `ffuf` não passa pelo ZAP e tem teto próprio.

6. SPA e as quatro camadas

- Camadas: telas, estáticos, API, dados do navegador.
- **Pegadinha:** rotas depois de `#/` não são requisições, porque o fragmento não vai ao servidor. A tela aparece na barra de endereço; no *History* aparecem os estáticos e as chamadas de API que ela dispara.
- **Client Spider:** sem usuário configurado, roda como visitante. Pode clicar em botões com efeito; usar duração curta (5 min). Depende do add-on *Client Side Integration* e da extensão no navegador.

7. Hipótese = premissa

- "O servidor confere o dono do objeto" é hipótese; "testar IDOR" não é.
- Priorizar por impacto, indício e custo do teste.

Caminho de estudo

Tempo total estimado: cerca de 4 h, mais 1 h de ensaio.

Ordem	Material	Onde	Foco	Tempo
1	Página da A21, lida como estudante	GitHub Pages ou `docs/aulas/A21-pentest-processo-referenciais-e-escopo.md`	Percurso até a Revisão rápida; responder C1–C4 antes de ver as respostas	40 min
2	Roteiro do trabalho v1.2	`../Trabalho-pentest/Roteiro_Pentest_JuiceShop_v1.2.html`	Seções 1–7 (visão, arquitetura, ROE, dupla, entregáveis, ferramentas, diário); P0; P1; 14.1 (linha de base)	40 min
3	Guia: Processo e referenciais	`docs/pentest/visaogeral.md`	O que é e o que não é um pentest; referenciais pela função	20 min
4	Guia: Escopo, ROE e diário	`docs/pentest/planejamento.md`	ROE → configuração; parada e recuperação; linha de base; formato do diário	20 min
5	Guia: ZAP	`docs/pentest/zap.md`	Contexto e modo; Rate Limit e Fuzzer; Client Spider; guardar evidência	20 min
6	Guia: Reconhecimento	`docs/pentest/coleta.md`	Quatro camadas da SPA; priorizar hipóteses; correspondência WSTG-INFO	20 min
7	NIST SP 800-115	PDF oficial	Seção 5.2 (pentest e suas fases) e apêndice B (modelo de ROE)	30 min
8	Documentação do ZAP	Modos, contextos, Rate Limit	Confirmar o comportamento que será demonstrado	15 min

Ordem	Material	Onde	Foco	Tempo
9	Anexos B e C da A21	Mesma página	Fichas e glossário, para responder perguntas laterais	20 min
10	Opcional: infraestrutura	Anexo A e `docs/pentest/infraestrutura.md`	Para o plantão da Parte 0/I e o checkpoint I0–I5, não para a aula	20 min
11	Ensaio prático	Computador de projeção	Preparação técnica descrita na condução da A21	60 min

Condução do encontro (100 min)

Versão de 12 nov. 2026, alinhada à página revisada (ROE no bloco Pentest; infraestrutura no Anexo A, fora do tempo de aula). A carga continua 60/40: cerca de 55 min de exposição com checkpoints e 45 min de demonstração conduzida.

Preparação técnica (antes do encontro)

- Ensaiar no computador de projeção: `docker run --rm -p 127.0.0.1:3000:3000 bkimminich/juice-shop:v20.3.0`; ZAP da série 2.17 com os add-ons Fuzzer, Requester, Network e Client Side Integration conferidos em *Marketplace → Installed*; *Manual Explore* abrindo o navegador.
- Deixar pronta uma sessão ZAP de reserva, já com contexto `^http://127\.0\.0\.1:3000(?:/.*)?$`, Rate Limit para `127.0.0.1` e uma conta `@lab.invalid`. Capturar contexto, modo, Rate Limit, Fuzzer e árvore *Sites* antes e depois do spider: são a alternativa se a demonstração falhar.
- Rodar uma vez o teste da expressão em Python com a expressão correta e a errada. Saídas conferidas: True/False/False e True/True/True.
- Conferir no Classroom se o trabalho já foi lançado. A atividade da página remete a ele, e a Parte 0/I precisa começar em paralelo.

Min	Bloco	Condução	Pergunta e resposta esperada
5	Abertura	Ler a frase do gestor e escrever no quadro as quatro perguntas (o quê, até onde, como parar, o que é prova). Mostrar a tabela de percurso.	"Por onde vocês começariam?" Respostas típicas: "rodar um scanner". Guardar a resposta para o C1.
15	Pentest e ROE	Comparar as quatro atividades na tabela. Na subseção do ROE, ligar cada pergunta do quadro ao item correspondente. Enfatizar quem assina e o art. 154-A.	C1 (ver respostas).
12	Ciclo	Diagrama SP 800-115 com o laço descoberta ↔ validação; tabela de fases P0–P13; "atacar = validar com a menor ação".	"Uma hipótese descartada leva de volta a qual fase?" → descoberta.
18	Referenciais	Só a tabela com a coluna "O que é", o quadro CVE × CWE × ATT&CK e o exemplo da mesma falha. Fichas e glossário ficam nos anexos e não são projetados.	C2.
20	ROE no ZAP	Explicar os dois limites de taxa e as partes da expressão **antes** de configurar. Demonstrar os passos 1–7, pausando para a turma prever o efeito do modo *Protected* e do Rate Limit. Rodar a contraprova.	C3: a turma prevê a saída com a expressão errada antes de você rodar.
15	Mapa	Navegar como visitante, fazer login, percorrer, capturar *Sites*, rodar o Client Spider (5 min). Mostrar a linha trabalhada fictícia e pedir à turma o preenchimento de um fluxo do Juice Shop.	"O que apareceu só depois do login?" "O que o spider achou que vocês não clicaram?"
10	Diário e fechamento	Exemplo trabalhado e comparação de prioridades; C4 em dupla; ler 2–3 hipóteses e reescrever como premissa. Fechar com a tabela "o que dá para responder ao gestor".	C4; "o portal é seguro?" → ainda não, nada foi testado.

Min	Bloco	Condução	Pergunta e resposta esperada
5	Encaminhamento	Atividade (trabalho); Anexo A para a Parte 0/I; checkpoint I0–I5 antes do período de pentest.	—

Cuidados de condução

- **Rotas da SPA.** Rotas depois de `#/` não viram requisições: o fragmento não é enviado ao servidor. As telas aparecem na barra de endereço; no *History* e na árvore *Sites* aparecem os estáticos e as chamadas de API que cada tela dispara. Antecipar isso evita a pergunta "por que a tela não está no ZAP?".
- **Client Spider.** Sem usuário configurado no contexto, ele roda como visitante. Ele pode clicar em botões com efeito; manter a duração curta e acompanhar o painel.
- **Sem respostas do Juice Shop.** Na demonstração aparecerão chamadas com identificadores (cesta, por exemplo). Registrar hipóteses da turma **sem confirmar nem testar**: a validação começa na A22. Não comentar se um desafio existe.
- **Tempo.** Se a demonstração atrasar, cortar o Client Spider ao vivo e mostrar as capturas de reserva. Não cortar o C4, porque ele é a ponte para a A22.

Respostas esperadas aos checkpoints

- **C1:** pulou o planejamento (não há ROE que autorize essa ação agora) e a validação. O ROE do trabalho só permite varredura ativa na P9, com até 30 minutos. Cada alerta precisa de hipótese, teste controlado e evidência para virar achado.
- **C2:** (a) WSTG (`SESS-06`); (b) CWE; (c) OWASP Risk Rating/contexto.
- **C3:** com `http://10.77.2.10:3000.*`, as três URLs saem `True`. `10x77x2x10` passa porque os pontos não têm escape (`\.`); `:30001` passa porque `.*` vem logo depois de `:3000`, sem exigir `/` ou fim (`(?:/.*)?$`). Como o ZAP compara a URL inteira, a falta de `^/$` não é o que abre a brecha aqui; ela importa em ferramentas que procuram trecho.
- **C4:** hipóteses nomeando a premissa, por exemplo sobre dono do objeto, validação de entrada na busca ou rota administrativa no frontend.

Pendências que podem surgir em aula

- Datas da A21–A24 e do lançamento do trabalho não estão definidas.
- O ensaio completo do roteiro no Learner Lab não foi feito.
- A figura de arquitetura do roteiro v1.2 contradiz o texto ("VPC da dupla", mas a infraestrutura é individual). Se perguntarem, vale o texto.